X-Content-Type-Options

The **`X-Content-Type-Options`** response HTTP header is a marker used by the server to indicate that the MIME types advertised in the `Content-Type` headers should be followed and not be changed. The header allows you to avoid MIME type sniffing by saying that the MIME types are deliberately configured.

This header was introduced by Microsoft in IE 8 as a way for webmasters to block content sniffing that was happening and could transform non-executable MIME types into executable MIME types. Since then, other browsers have introduced it, even if their MIME sniffing algorithms were less aggressive.

Starting with Firefox 72, top-level documents also avoid MIME sniffing (if `Content-type` is provided). This can cause HTML web pages to be downloaded instead of being rendered when they are served with a MIME type other than text/html. Make sure to set both headers correctly. Site security testers usually expect this header to be set.

Note: `X-Content-Type-Options` only apply request-blocking due to `nosniff` for request destinations of `"script"` and `"style"`. However, it also enables Cross-Origin Read Blocking (CORB) protection for HTML, TXT, JSON and XML files (excluding SVG `image/svg+xml`).

Header type	Response header
Forbidden header name	no

Syntax

```
X-Content-Type-Options: nosniff
```

Directives

`nosniff`

Blocks a request if the request destination is of type style and the MIME type is not `text/css`, or of type `script` and the MIME type is not a JavaScript MIME type.

Specifications

Fetch Standard # x-content-type-options-header

This lesson is adapted from MDN web Docs: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options